תבנית מסמך הגדרת מאגר ושורת נוהל אירוע (עברית)

מסמך	תבנית מסמך הגדרת מאגר ושורת נוהל אירוע (עברית)
נתיב המקור	docs/privacy/he/05-database-definition-and-incident-line-template.md
גרסת המקור	origin/main @ b6eb212ec
הוכן לחבילה	2026-10-24
מצב	הנוסח המקורי נשמר ללא שינוי; עיצוב בלבד. טיוטה לבדיקת עורך דין, אינו ייעוץ משפטי.

---

05 - תבנית מסמך הגדרות מאגר ושורת נוהל אירועים

סטטוס: תבנית, טיוטה. אין זו חוות דעת משפטית. הארגון ממלא את `[הסוגריים]`; שורות שמולאו מהקוד הן עובדות שאומתו מול `smplwise_vms/backend/smplwise/` = `B/` (19.10.2026), `018795f96` @ `origin/integ/290`. האם הארגון זקוק למסמך כזה, מה הדין מחייב שיכלול, האם המאגר טעון רישום ואיזו רמת אבטחה חלה: **REQUIRES COUNSEL REVIEW (C4)**. השם "מסמך הגדרות מאגר" משמש כי החלטת הבעלים מ-18.10.2026 ביקשה אותו; לא נטענת משמעות משפטית לשם. הנוסח האנגלי ב-`../en/` הוא המקור המדויק.

חלק א - מסמך הגדרות מאגר (ממלאים, ואז בחינה משפטית)

#	פריט	תוכן
1	הארגון (בעל המידע)	[שם, ח.פ., כתובת] **REQUIRES COUNSEL REVIEW (C1)**
2	האחראי על המאגר / איש קשר לפרטיות	[שם, תפקיד, פרטי קשר]
3	מערכת	גישת SmplWise. :על [תיאור השרת, מיקום]. ספקית Home Assistant גרסה [גרסה], רצה כתוסף SmplWise Arx, הספקית לשרת: [כן/לא, איך, מתי] **REQUIRES COUNSEL REVIEW (C1)**
4	אחסון	מסד SQLite מקומי אחד `smplwise.db` וקבצים בתיקיית הנתונים של התוסף (`B/config.py`); בקוד אין עותק שמפעילה SmplWise. גיבויים: `<data>/backups`, נשמרים 5 לפני שדרוג + 7 יומיים (`B/services/backup.py`); עותקים במקום אחר: [איפה / מי / מוצפן?] **REQUIRES COUNSEL REVIEW (C8)**
5	מטרות	[הארגון מגדיר: הפעלת המבנה ואבטחתו, קריאות שירות, ניהול ספקים, בקרת כניסה, אחריותיות צוות...]
6	קטגוריות מידע	בחרו מ-`01-data-processing-summary.md` סעיף 2 (A-J); סמנו מה מופעל באתר (קריאות `tickets.enabled`; גישת דלתות חיצונית `access.external_grants` כבויה ואי אפשר להפעילה בגרסה זו; נוכחות בטלפון `presence.*` כבויה כברירת מחדל)
7	קטגוריות אנשים	צוות, ספקים והטכנאים שלהם, מי שפותח קריאות, [אחרים]
8	מקורות המידע	מוקלד על ידי צוות; מוקלד על ידי ספקים בדפים ציבוריים; מיובא מ-Home Assistant (זהות, מכשירים); מדווח מאפליקציית הטלפון; נקרא ממערכת הכניסה ומהמקליטים
9	נמענים ושירותים חיצוניים	הטבלה ב-`01-data-processing-summary.md` סעיף 5, בהשלמת [הסכמים שבידינו] **REQUIRES COUNSEL REVIEW (C5, C6, C7)**
10	העברות מחוץ למדינה	[לאן; על מה מבוסס] **REQUIRES COUNSEL REVIEW (C5, C6)**

#	פריט	תוכן
11	מי רשאי לגשת ואיך ניתנת גישה	תפקידים והרשאות מוגבלות היקף (`B/roles.json`, `B/rbac.py`; `docs/security/HA_IDENTITY_RBAC_HE.md`); רשימת בעלי `tickets.configure`, `system.configure`, `backup.manage`, `audit.read`, `access.external.grant`: [שמות, תאריך בדיקה]; סקירת הרשאות כל [תקופה]. הערה: מנהל המארח יכול להגיע לנתונים מחוץ לבקרת הגישה של Arx (`docs/security/HA_IDENTITY_RBAC_HE.md` סעיף 2)
12	הזדהות	זהות Home Assistant, או חשבונות מקומיים עם גיבוב סיסמה scrypt/argon2id, passkeys ו-TOTP אופציונליים (`B/services/local_passkeys.py`, `B/services/local_identity.py`); מגבלות סשן (`B/services/local_identity.py`)
13	אמצעי אבטחה בקוד	בקרת גישה, ביקורת כתיבות, אסימונים/סשנים מגובבים, הגבלות קצב, תשובות כשל אחידות בדפים ציבוריים, בלי קוד אישי או טלפון בשורות ביקורת וביומנים (`01-data-processing-summary.md` סעיף 6; `docs/security/`). אמצעים ארגוניים (גישה פיזית לשרת, עדכונים, הגנת גיבויים): [הארגון ממלא] **REQUIRES COUNSEL REVIEW (C4)**
14	רישום וניטור	יומן ביקורת (ברירת מחדל 365 יום, `audit.retention_days`); מי בודק ובאיזו תדירות: [למלא]
15	שמירה	ממולא `06-retention-policy-template.md`
16	טיפול בבקשות אנשים	**REQUIRES COUNSEL REVIEW (C11)** עם אחראי בשם [שם], `03-data-subject-request-handling.md`
17	נוהל אירועים	חלק ב
18	סקירת המסמך	כל [תקופה] ובכל שינוי של מטרות, נמענים או גרסת מערכת; סקירה אחרונה [תאריך]

חלק ב - שורת נוהל אירועים

שורה אחת שהארגון יכול להוסיף לנוהל האבטחה שלו. ניסוח החובות, מי צריך לדעת ובתוך כמה זמן - עניינים משפטיים: **REQUIRES COUNSEL REVIEW (C12)**.

> **שורת אירוע.** מי שמבחין או חושד שמידע אישי שמטופל ב-SmplWise Arx אבד, נשלח לאדם הלא נכון, או נצפה או שונה על ידי מי שאינו מורשה (כולל טלפון שאבד עם האפליקציה, קישור או קוד כניסה שדלף, או גיבוי שנגנב) מודיע מיד ל-[איש קשר לאירועים, טלפון / דוא"ל]; [איש הקשר לאירועים] רושם את השעה, מה קרה ומה נעשה, ומחליט עם [יועץ / ממונה] אם צריך להודיע למישהו נוסף ועד מתי.

צעדים טכניים שהמוצר מציע כשחושדים באירוע (עובדות; ההחלטה להשתמש בהם היא של הארגון):

- ביטול מיידי של כל הגישה החיצונית לדלתות: פעולת מנהל "בטל הכל" (`POST /access-grants/revoke-all`, מקלידים מילת אישור, מתועד `access.grant.revoke_all`).
- ביטול הרשאה אחת או הנפקה מחדש של קוד (`/access-grants/{id}/revoke`, `/rotate`; עד 3 שליחות להרשאה).
- ביטול קישור ספק או איש קשר (קישור חדש או השבתת איש הקשר: קישורים חיים מתבטלים מיד, `B/services/tickets/contacts.py`).
- ביטול מכשיר אפליקציה (`DELETE` של המכשיר; גיבוב האסימון מוחלף, הנוכחות ורישום הדחיפה מנוקים, `B/services/presence.py`); אפשר להשעות את מדיניות החיישנים הנדרשים ברשומת break-glass.
- השבתת חשבון מקומי או ביטול הסשנים שלו; הסרת גישה מרחוק של משתמש (`B/services/local_identity.py`, `B/routers/remote.py`).
- ראיות: יומן הביקורת (`audit.read`) והתראות תשומת הלב על הרשאות (בלי תוכן) מצביעים על מה שקרה; גיבוי אינו יומן.

מה שהמוצר אינו מספק: זיהוי אוטומטי של הפרות, פנקס אירועים, תבניות הודעה לרשויות או ליחידים. **REQUIRES COUNSEL REVIEW (C12)**.